

Module 1

IR Frameworks: NIST CSF

- Identify
- Protect
- Detect
- Respond
- Recover
- Govern

Preparation → detection and analysis

↓
Containment, eradication and recovery → post-incident

an incident jeopardises the CIA of information.

Consider the 5 W's of an incident: who, what, when, where, why.

CSIRT - trained teams in incident response

- ↳ analyst - examine and triage alerts
- ↳ Tech lead - guides analysts through process
- ↳ Incident coordinator - handles response

There are also SOC teams.

- ↳ analyst L1 - gauge and exclude alerts
- ↳ analyst L2 - investigating and confirming
- ↳ lead - manage operations, advanced security
- ↳ manager - hiring and training, oversight

Incident plans:

- ↳ response procedures
- ↳ system information
- ↳ contact lists

Incident plans should be living documents and trained on.

analysts need to use detection tools, case tools, documentation tools to perform their duties

Documentation

any form of recorded content as a specific process.

Types:

- ↳ Playbooks
- ↳ IR Plans
- ↳ Contact sheets
- ↳ Policy books

Playbooks detail operational actions.

Ticketing systems are often used for case documentation.

IDS / IPS

IDS monitor system and network activity and alert on abnormal events.

an IPS can also act on intrusions and perform actions.

IDS / IPS:

- ↳ Snort
- ↳ Zeek
- ↳ Suricata
- ↳ Kismet

EDRs monitor endpoints for malicious activity

SIEM

collects and analyses log data.

1. Collect and aggregate
2. Normalise
3. Analyse
4. Visualise

SOAR - Security orchestration automation ^{response} tools
↳ for automating IR or case management

Module 2

data exfiltration - unauthorised removal of data, off-network

IOCs - indicators of compromise

It is very important to collect a baseline so you know what traffic is normal on the network.

You might find abnormal behavior by:

- ↳ Flow analysis
- ↳ Packet payload information
- ↳ Temporal patterns

Defence against data exfil requires detecting the critical assets, monitoring network activity, protecting assets and detection/eradication.

Packets

{ header
 Body
 Footer

ports - non physical locations that determine protocol handling

Network protocol analysers capture packets on the network.

tcpdump and Wireshark are two NTA's

IP Headers

Different protocols use different headers.

IPv4

Version → which IP version?

IHL → internet header length

TOS → type of service, should packets be handled differently

Total length → length inc headers

{ Id →

Flags → deals with fragmentation and reassembly

Fragment offset →

MTU → time to live

Protocol → number representing

Checksum → used to verify integrity

Source IP → sender address

Dest IP → recipient address

Options → not required, for debugging

IPv6

Version

Traffic class → Priority

Flow label → identifies flow, stream of packets

Payload length

Next header → i.e. TCP

Hop limit → TTL

Source

Dest

tcpdump

- CLI tool
- NTA tool

Sudo tcpdump -i any -v -c 1

↑ ↑ ↓ ↓ ↓

elevate start any verbose Capture 1 packet

interface

DF flag means "Don't Fragment"

Module 3

all incidents are events but not all events are incidents

analysis involves investigation and verification

difficulties include:

- ↳ limited resources
- ↳ unavoidable incidents
- ↳ high alert volume
- ↳ not everything can be detected

CI/CD pipelines can introduce new threats into an environment, these need to be monitored. such threats include

- ↳ unauthorized code changes.
- ↳ suspicious deployment
- ↳ compromised dependencies
- ↳ secrets exposure
- ↳ unusual pipeline execution

IOCs are observable evidence that suggest a security incident has occurred. IOAs are used during an ongoing attack.

Principles of documentation:

- ↳ transparency
- ↳ standardisation
- ↳ clarity

Chain of custody is the process of documenting evidence collection, possession and control throughout the investigative lifecycle.

Chain of custody forms usually contain a list of numbers about the evidence and a custody chart

Broken chain of custody is when there are errors.

Chain of custody forms are incredibly important in legal proceedings

Playbooks provide a list of actions that teams need to take when responding to an incident.

playbooks are in 3 types:

- ↳ automated → lowers time to resolution
- ↳ non-automated → human only
- ↳ semi-automated → combine human actions with automation

Triage helps manage prioritising incidents. It aids in resource allocation.

Triage process:

- ↳ receive and verify
- ↳ assign priority
- ↳ collect and analyse

Containment/ Strategies will vary based on the type of incident. Once contained, the critical elements need to be removed or eradicated.

Finally we need to perform recovery to bring back systems to normal conditions.

Business Continuity plans outlines the procedures needed to sustain normal business operations during an incident.

Post incident involves reviewing what an incident.

This involves:

- ↳ creating a final report
- ↳ updating playbooks
- ↳ lessons learned meeting.

Module 4

events are observables on a network or device.

logs are records of events

- ↳ what
- ↳ where
- ↳ when
- ↳ who

Not all log data will be relevant to an incident

SIEM tools aggregate logs to help analysts process large amounts of log data.

logs are sent to the SIEM through log forwarders

Different log sources will be formatted in different ways:

- ↳ Syslog → Header, Structured, Message
- ↳ JSON → text-based, key-value pairs, human-readable
- ↳ XML
- ↳ CSV
- ↳ GEF

IDS monitors activities and alerts on intrusions.

Host-based IDS run on endpoints and hosts to collect logs

Signature analysis is using a set of rules to generate an alert from logs

You should have a mixture of signature analysis and anomaly analysis to balance the pros and cons.

Generally NIDS rules specify an action, a header and a rule options section.

alert http \$HOME_NET any → \$EXTERNAL_NET any
msg:"Get online"; flow:established; content:"GET")

Suricata captures logs in a format called EVE JSON

SIEM tools process huge amounts of data from many sources. They have to normalize it so that events can be correlated

Google's SIEM uses the YARA-L language for searching. There are different search types:

- ↳ UDM
- ↳ Raw log